

DHR REST API Documentation (with cURL)

This document describes the REST API exposed by the DHR bot and provides ready-to-run `curl` examples.

1) Base URL and Auth Flow

- Default base URL: `http://127.0.0.1:8080/api/v1`
- Public endpoint:
 - `GET /health`
- Authentication flow:
 1. Call `POST /auth/login` with `username` + `password`
 2. Receive JWT access token
 3. Use `Authorization: Bearer <token>` on all protected endpoints

Access token validity is controlled by `API_JWT_ACCESS_TTL_SEC` (default: `1800` = 30 minutes).

API users are stored in database table `api_users`.

`API_AUTH_*` env credentials are optional bootstrap seeds imported at startup.

2) Quick Variables

```
export BASE_URL="http://127.0.0.1:8080/api/v1"
export USERNAME="vendor1"
export PASSWORD="YourStrongPassword"
```

3) Health Check (No Auth)

```
curl -s "$BASE_URL/health"
```

4) Login and Get JWT

```
LOGIN_RESPONSE=$(curl -s "$BASE_URL/auth/login" \
-H "Content-Type: application/json" \
-d '{"username":"'${USERNAME}'","password":"'${PASSWORD}'"}')

echo "$LOGIN_RESPONSE"
```

Extract token with `jq` :

```
export TOKEN=$(echo "$LOGIN_RESPONSE" | jq -r '.accessToken')
```

If `jq` is not installed:

```
export TOKEN=$(echo "$LOGIN_RESPONSE" | sed -n 's/.*"accessToken": "\([^"]*\)".*/\1/p')
```

5) Protected Endpoints (Customer/User)

5.1 Quote

POST /quote

```
curl -s "$BASE_URL/quote" \
  -H "Authorization: Bearer $TOKEN" \
  -H "Content-Type: application/json" \
  -d '{"ph":1,"hours":12}'
```

5.2 Rent / Create Order

POST /rent

```
curl -s "$BASE_URL/rent" \
  -H "Authorization: Bearer $TOKEN" \
  -H "Content-Type: application/json" \
  -d '{
    "ph": 1,
    "hours": 12,
    "pool": "stratum+tcp://yourpool:3333",
    "worker": "1BoatSLRHtKNgkdXEeobR76b53LETpyT"
  }'
```

Save created order id:

```
export ORDER_ID="<paste-order-id>"
```

5.3 Order Status

GET /orders/:id

```
curl -s "$BASE_URL/orders/$ORDER_ID" \
  -H "Authorization: Bearer $TOKEN"
```

5.4 Time Left

GET /orders/:id/time_left

```
curl -s "$BASE_URL/orders/$ORDER_ID/time_left" \
  -H "Authorization: Bearer $TOKEN"
```

5.5 Cancel Order

POST /orders/:id/cancel

```
curl -s -X POST "$BASE_URL/orders/$ORDER_ID/cancel" \
-H "Authorization: Bearer $TOKEN"
```

5.6 Payment Status

GET /orders/:id/payment_status

```
curl -s "$BASE_URL/orders/$ORDER_ID/payment_status" \
-H "Authorization: Bearer $TOKEN"
```

6) Admin Endpoints

Use an admin token (role/scope configured by `API_ADMIN_ROLES` / `API_ADMIN_SCOPES`).

```
export ADMIN_USERNAME="ops-admin"
export ADMIN_PASSWORD="AdminStrongPassword"

ADMIN_LOGIN_RESPONSE=$(curl -s "$BASE_URL/auth/login" \
-H "Content-Type: application/json" \
-d '{"username":"$ADMIN_USERNAME","password":"$ADMIN_PASSWORD"}')

export ADMIN_TOKEN=$(echo "$ADMIN_LOGIN_RESPONSE" | jq -r '.accessToken')
```

6.1 List API Users

GET /auth/users

```
curl -s "$BASE_URL/auth/users" \
-H "Authorization: Bearer $ADMIN_TOKEN"
```

6.2 Create API User

POST /auth/users

```
curl -s -X POST "$BASE_URL/auth/users" \
-H "Authorization: Bearer $ADMIN_TOKEN" \
-H "Content-Type: application/json" \
-d '{
  "username": "vendor2",
  "password": "Vendor2StrongPass!",
  "subject": "vendor2",
  "roles": ["user"],
  "scopes": ["orders:read","orders:write"],
```

```
"isActive": true
}'
```

6.3 Update API User (roles/password/status)

PATCH /auth/users/:username

```
curl -s -X PATCH "$BASE_URL/auth/users/vendor2" \
-H "Authorization: Bearer $ADMIN_TOKEN" \
-H "Content-Type: application/json" \
-d '{
  "roles": ["admin"],
  "scopes": ["admin"],
  "password": "NewVendor2StrongPass!",
  "isActive": true
}'
```

6.4 Mark Paid (Manual Fulfillment Trigger)

POST /orders/:id/mark_paid

```
curl -s -X POST "$BASE_URL/orders/$ORDER_ID/mark_paid" \
-H "Authorization: Bearer $ADMIN_TOKEN"
```

6.5 Verify Payments

POST /payments/verify

```
curl -s -X POST "$BASE_URL/payments/verify" \
-H "Authorization: Bearer $ADMIN_TOKEN"
```

6.6 Verify Payments Debug

POST /payments/verify_debug

```
curl -s -X POST "$BASE_URL/payments/verify_debug" \
-H "Authorization: Bearer $ADMIN_TOKEN" \
-H "Content-Type: application/json" \
-d '{"limit":10}'
```

6.7 Finance Summary

GET /finance/summary

```
curl -s "$BASE_URL/finance/summary" \
-H "Authorization: Bearer $ADMIN_TOKEN"
```

7) Error Format

Typical error response:

```
{
  "ok": false,
  "error": "unauthorized",
  "message": "Invalid username or password"
}
```

Common error values:

- unauthorized
- forbidden
- validation_error
- rate_limited
- not_found
- internal_error

8) Security Notes

- Run API behind HTTPS (reverse proxy or load balancer).
- Keep JWT keys/secrets in secure secret storage.
- Use strong bcrypt password hashes for API_AUTH_* credentials.
- Use admin endpoints to manage users/roles instead of editing .env .
- Rotate credentials and keys regularly.